

6. DEALING WITH CHANGES

What happens to PCI DSS compliance if certain things change, in various contexts?



IMPLEMENTATION

IMPLEMENTATION DEALING WITH CHANGES

Compliance is not static - there are various elements, that, upon change, can cause changes to your compliance. We're going to examine nine main types:

1. Changes in payment methods or systems;
2. Changes in PCI DSS versions;
3. Changes in network configurations;
4. Changes in software applications or their vulnerabilities;
5. Changes in pentesting/vuln. scanning vulnerabilities;
6. Changes in user roles or access privileges;
7. Changes in systems or servers in the CDE;
8. Changes in third-party service providers (TPSPs);
9. Changes in cryptographic techniques/key practices;

IMPLEMENTATION DEALING WITH CHANGES

Changes in payment methods or systems demand a re-assessment of the PCI DSS scope - and SAQ category:

- Imagine you fully outsource payments (SAQ A). You decide to build your own payment portal (you're now SAQ D);
- Imagine you only do local P2PE device payments (SAQ P2PE) and open an online shop. You have to assess for the requirements of that online shop too, and add them;

Likewise, changes in PCI DSS versions means reassessing, according to the timelines allowed:

- In many cases, the main SAQ categories remain the same, save for certain details, so an SAQ category may remain the same. But we must understand the new categories, still;





IMPLEMENTATION

IMPLEMENTATION DEALING WITH CHANGES

Changes in network configurations are usually dealt with by the change management process (as per Req. 1):

- We gauge what we need to change in configurations, update diagrams if necessary, review whether security controls still perform their job, and change the policy;
- We may immediately reflect the new policy on all devices;

Changes in software applications or their vulnerabilities are managed by our code assessments and patching (Req. 6):

- If it's a change in an internal application, it's usually caught in code reviews and assessments, and its impact evaluated;
- If it's a change in app vulnerabilities (from official third-party announcements, intel forums, etc), it's immediately ranked, and inserted in the patching calendar;

IMPLEMENTATION

DEALING WITH CHANGES

Changes in new vulnerabilities resulting from penetration testing/vulnerability scanning follow the process from Req. 11:

- We rank the vulnerability, and, if it's an external vulnerability with a CVSS score of 4.0 or higher, it must be resolved (appropriate timeline);
- We re-scan again after resolving these vulnerabilities (besides the usual scans we already run);

Changes in user roles or access privileges mean a re-evaluation of our access control policies (per Req. 7):

- We must ensure these changes still reflect access to the least CHD possible, and for the least amount of time;
- We must ensure these changes are reflected in our AC system, and that they are properly enforced and in effect;





IMPLEMENTATION

IMPLEMENTATION DEALING WITH CHANGES

Changes in systems or servers in the CDE merit a re-evaluation of the full PCI DSS scope:

- Then, it's a matter of reflecting the appropriate area's policies/processes (e.g., if it's a new website, applying secure development principles from Req. 6. If it's a new networking system, applying configurations from Req. 1);

Changes in third-party service providers (TPSPs) affect our general Information Security policy (as per Req. 12):

- We must reflect these changes in our inventory, as well as obtain the PCI DSS compliance status of these TPSPs, and/or formal acknowledgment of CHD protection by them in contracts;

IMPLEMENTATION

DEALING WITH CHANGES

Finally, changes in cryptographic techniques/key practices mean reflecting these in our policies to protect data both at rest and in transit (as per Req. 3 and/or Req. 4):

- We must ensure that all data are still encrypted, with strong encryption, and valid, non-expired keys;
- We must ensure that key-encrypting keys are still equal or stronger than data-encrypting keys;
- We must still ensure good encryption hygiene, such as having a cryptoperiod, having proper methods to retire or renew these keys, minimizing storage locations and people who know about these;



IMPLEMENTATION

DEALING WITH CHANGES

EXAMPLES

/01 CHANGES TO THE CDE

Additions to the CDE (new systems, networks, apps), seem big, but they can be very simple. We already have all policies - just apply them to the new element.

/02 ALREADY PLANNED

Most requirements already require formal change process for new elements. When they don't, just ensure the new element still follows requirements.

/03 REMEMBER ADDITIONS

When you add new payment methods or systems, remember that you don't replace the SAQ - you add it. You may have a mixture of SAQs from various sources.

IMPLEMENTATION

DEALING WITH CHANGES

KEY TAKEAWAYS

/01 CHANGES IN PAYMENT

Changes in our payment equipment or portals merit re-evaluating PCI DSS compliance, including our SAQ category.

/03 CHANGES IN NETWORKING

Changes in networking equipment must go through change management, and we may need to change our two diagrams and/or our system configurations.

/05 CHANGES IN VULNERABILIS.

We must ensure that all external vulnerabilities ≥ 4.0 CVSS are resolved, and re-scan after their resolution. Lower priority vulnerabilities may be resolved later.

/02 CHANGES IN THE PCI DSS

Changes in future PCI DSS versions merit re-assessing ourselves according to new categories, understanding the changes in the new version that may apply.

/04 CHANGES IN APPS/VULNER.

Changes in internal applications are caught in code reviews/assessments. Changes in vulnerabilities are ranked, with critical ones to be patched in 30 days.

IMPLEMENTATION

DEALING WITH CHANGES

KEY TAKEAWAYS

/06 CHANGES IN AC

We must ensure that new privileges still reflect need-to-know and PoLP, we must codify them into our AC mechanism, and ensure it enforces them.

/08 CHANGES IN TPSPs

We must ensure we keep all service providers inventoried, obtain PCI DSS compliance status from them, and acknowledgment of CHD protection.

/07 CHANGES IN CDE

Changes in systems or applications in the CDE means re-assessing our scope, and applying PCI DSS policies to the new system or application to integrate it.

/09 CHANGES IN ENCRYPTION

We must ensure new encryption is strong, all data are still encrypted at rest and in transit, and good encryption hygiene is still practiced.